



File No.: EXP202210236

RESOLUTION OF

PROCEEDING OF WARNING

From the proceeding initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: As a consequence of the notification to the Division of Technological Innovation of this Agency regarding a personal data breach by the data controller POZO LIMPIO SL (LAOOAL VECINDARIO) (hereinafter, the notifying entity), with entry registration number ***NUMBER.1 related to a cyber incident, the General Subdirectorate of Data Inspection is ordered to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations. In the aforementioned notification, the Spanish Agency for Data Protection was informed that a mobile phone device owned by the entity had been stolen, which contained photographs of patients' intimate parts before and after aesthetic treatments. It was also stated that there was no evidence of any material damage and that the device was turned off and protected with a password and access pattern. It is stated that the stolen device contains data of minors, as well as personal data of individuals from other countries.

SECOND: In light of the above, the General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the details that are subsequently presented.

Regarding the facts, in the terms indicated by the notifying entity, a mobile phone device has been stolen from a clinic, which contains photographs of patients' intimate parts before and after aesthetic treatments. Apparently, the employee who usually works at the reception was absent from the location carrying out a task, at which point an unidentified third party took advantage of her brief absence to appropriate the mobile device.

The compromised data would consist of identifying, contact, image, and health data of approximately 150 affected individuals, including minors and four affected individuals from other countries.

Specifically, it is stated that the breach may have affected one individual in Germany, another in France, one in Italy, and another individual in the Netherlands. There is a certain probability that it may have affected a client located in Brazil.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/8

The entity states that it has no record of the use of the data contained in the device and that, after an analysis in various Internet search engines, no evidence of publications regarding this matter has been found.

Furthermore, it is noted that a complaint was filed with the State Security Forces regarding these events.

As for the nature of the notifying entity, it is a limited liability company of Spanish nationality that is listed as a subsidiary of a group, and its activity consists of "Washing and cleaning of textile and leather garments."

On 30/09/2022, and by virtue of the provisions of Article 34.4 of Regulation (EU) 2016/679 General Data Protection Regulation (hereinafter GDPR), a resolution was issued by the present authority through which the notifying entity was obliged to inform the affected parties of the security breach that occurred.

In compliance with the aforementioned resolution, the notifying entity reports that the breach occurred within the indicated timeframe, on October 18 and 21, 2022, via WhatsApp, of which a copy is provided. It states that, although 150 affected individuals were estimated, proactively and given the impossibility of specifying which individuals were affected by the incident, communication was made to a total of 1430 individuals. The text of the message informs of the theft of the device that contained customer information, stating that there is no record of access to the affected data since the device was protected with a security pattern and PIN code. They also inform that they have reported this to the State Security Forces and include an address to contact the data protection officer (infodpo@forlopd.es).

Regarding the security measures implemented, the entity has provided the following documents:

- A record of processing activities where the processing "Taking and comparing images to verify the effectiveness of the treatment" is listed.
- A Risk Analysis of the aforementioned processing where the controls to be applied are indicated, as it is considered HIGH risk. However, given the security measures for device access (pattern and PIN), they claim that the risk is low since accessing the content "requires formatting it, resulting in the deletion of all data stored on it."

The entity states that it has contracted data protection consulting services, as well as advice and supervision as an external Data Protection Officer since December 2019, and provides a "Manual of security measures" related to data protection implemented in the entity prior to the incident. This document defines the proper use of the organization's resources concerning technological devices, including a series of security measures applicable to any device used for work purposes.

In this regard, the entity states that, despite the security measures implemented, it was unable to prevent the theft of the device.

Regarding the measures implemented after the security breach, it claims to have implemented a specific device for images with access to content and remote formatting along with a robust password. This device has been stored in areas not accessible to the public and is only...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

will be used by certain employees. Furthermore, the period for transferring images to the Computer System and deleting content on devices has been reduced. It also states that the procedures for training and awareness actions have already begun.

Lastly, regarding the possible recurrence of these events and the number of similar incidents that have occurred over time, the entity claims not to have suffered any security event that compromised the personal data of clients and patients.

THIRD: On September 15, 2023, the Director of the Spanish Agency for Data Protection decided to initiate a warning procedure against the notifying entity for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

FOURTH: The notification of the aforementioned initiation agreement, which was carried out in accordance with the regulations established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on December 13, 2023, as evidenced by the acknowledgment of receipt in the file.

FIFTH: Once the deadline for submitting allegations had passed, it was confirmed that no allegations had been received from the notifying entity.

In light of all the actions taken, the Spanish Agency for Data Protection considers the following facts to be proven in this procedure,

PROVEN FACTS

FIRST: As evidenced by the investigation proceedings, the theft of a mobile phone device from a location of the notifying entity is confirmed, which contained photographs of patients' intimate parts before and after aesthetic treatments. This incident occurred due to the temporary absence of the employee who usually worked at the reception while performing a task, a moment that was exploited

by an unidentified third party to appropriate the mobile device.

SECOND: The compromised data consists of identifying, contact, image, and health data of approximately 150 affected individuals, including minors and four individuals from other countries.

Given the impossibility of specifically determining the individuals affected by the incident, the notifying entity communicated the breach to a total of 1,430 clients.

THIRD: To date, there has been no evidence of the use of the data contained in the device or evidence of publications on the Internet related to that content.

LEGAL GROUNDS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/8

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR and as established in Articles 47, 48.1, and 64.3 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Obligation Breached

Regarding the security of processing, Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/8

have access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law."

In the present case, from the investigative actions carried out, as well as from the statements made by the notifying entity, it is evident that appropriate technical and organizational measures were not applied to ensure a level of security adequate to the risk. This risk, as the entity itself has stated, is considerably high, considering the personal data being processed, which included sensitive information about patients, including minors among those affected.

The failure to apply appropriate measures is manifested in the very facts that occurred, as the theft of the device took place without any force or intimidation; on the contrary, it was sufficient for someone outside the entity to take the device due to a simple lapse or temporary abandonment of the workplace.

III

Classification and qualification of the infringement

In accordance with the facts described in this resolution, it is considered that the notifying entity has failed to comply with the obligation set forth in the aforementioned Article 32.1, which consists of adopting appropriate technical and organizational measures to ensure an adequate level of security. The failure to comply with this obligation constitutes an infringement, attributable to the notifying entity POZO LIMPIO SL (LAOOAL VECINDARIO), as provided for in Article 83.4 of the GDPR, which expressly states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;"

For the purposes of the statute of limitations for infringements, the infringement attributed prescribes after two years, in accordance with Article 73 f) of the LOPDGDD, which qualifies the following conduct as serious:

"f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679]."

IV

Warning

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/8

Without prejudice to the provisions of the aforementioned Article 83 of the GDPR, the said Regulation provides in paragraph 2.b) of Article 58 "Powers" the following:

"Each supervisory authority shall have all of the following corrective powers indicated below:

(...)

b) issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation; (...)"

For its part, Recital 148 of the GDPR states:

"In order to reinforce the application of the rules of this Regulation, any infringement of it must be punished with sanctions, including administrative fines, in addition to appropriate measures imposed by the supervisory authority under this Regulation, or in substitution of these. In the case of a minor infringement, or if the fine that would likely be imposed constitutes a disproportionate burden for a natural person, a warning may be issued instead of a fine. However, special attention must be paid to the nature, gravity, and duration of the infringement, its intentional character, the measures taken to mitigate the damages suffered, the degree of responsibility or any relevant previous infringements, the manner in which the supervisory authority became aware of the infringement, compliance with

measures ordered against the controller or processor, adherence to codes of conduct, and any other aggravating or mitigating circumstances. The imposition of sanctions, including administrative fines, must be subject to sufficient procedural guarantees in accordance with the general principles of Union law and the Charter, including the right to effective judicial protection and to a process with all guarantees."

Furthermore, Article 64 of the LOPDGDD, which regulates the "Form of initiation of the procedure and duration," in its third paragraph states that:

"3. When appropriate, considering the nature of the facts and duly taking into account the criteria established in Article 83.2 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, the Spanish Data Protection Agency, after hearing the controller or processor, may issue a warning, as well as order the controller or processor to adopt corrective measures aimed at ending the possible non-compliance with data protection legislation in a specific manner and within the specified time frame.

The procedure shall have a maximum duration of six months from the date of the initiation agreement. After this period, it will become void, and consequently, the file of actions will be archived.

The provisions of the second and third paragraphs of paragraph 2 of this article shall apply in this case."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/8

From the wording of the aforementioned provision, it follows that the classification of the infringement as minor does not depend on the qualification made by the law itself, since it is, as indicated by the article itself, solely for the purpose of the statute of limitations for the infringement. On the contrary, to determine the minor nature of the infringement, it is necessary to refer to the criteria set forth in Article 83.2 of the GDPR, among which are: the nature, severity, and duration of the infringement, the intent or negligence, the measures taken to mitigate the damage, the degree of responsibility, or the degree of cooperation with the supervisory authority, among others.

In the present case, as evidenced by the investigative actions, although the data contained in the stolen device was sensitive, said device was protected with a password and access pattern, which makes access to the mentioned data by unauthorized persons unlikely. Furthermore, the absence of intent on the part of the infringing entity is noteworthy, and the level of negligence can be classified as minor. It is also noted that the entity diligently communicated the security breach to the affected parties by expanding the number of recipients and applying a broad criterion when determining the possible affected parties.

For the reasons stated and applying the indicated criteria, it is considered lawful not to impose a sanction consisting of an administrative fine and to replace it with a warning directed to the infringing entity; all this without prejudice to the adoption of measures imposed in this resolution in the terms set forth below.

V

Measures to be adopted

Article 58.2 d) of the GDPR allows each supervisory authority the possibility to "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time frame..."

In the present case, the controller is required to notify this Agency within three months of the adoption of the following measures:

- Adopt the appropriate organizational and technical measures to ensure an adequate level of security commensurate with the risk and to avoid, as far as possible, the occurrence of a new security breach. It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of this procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning proceedings.

For the reasons stated, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/8

FIRST: TO ISSUE A WARNING to POZO LIMPIO SL (LAOOAL VECINDARIO), with NIF B88318290, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

SECOND: TO ORDER POZO LIMPIO SL (LAOOAL VECINDARIO), with NIF B88318290, to comply with Article 58.2.d) of the GDPR, within a period of three months, to demonstrate that it has implemented the following measures, communicating this to the present authority within that timeframe:

- Adopt the appropriate organizational and technical measures necessary to ensure an adequate level of security relative to the risk and to avoid, as much as possible, the occurrence of a new security breach.

SECOND: TO NOTIFY this resolution to POZO LIMPIO SL (LAOOAL VECINDARIO).

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

1403-21112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es